

VULNERABILITY ASSESSMENT

Vulnerability Scan Report

Executive Summary

This report outlines the findings of a vulnerability assessment conducted on the Ghana Maritime Defense Command (GMDC) Metasploitable 2 lab infrastructure. The objective of this scan was to establish a baseline of security weaknesses across the target scope (192.168.1.3 and 192.168.122.4). The assessment revealed a critical risk posture, identifying severe vulnerabilities including exposed malicious backdoors, unauthenticated remote code execution (RCE) flaws, default database credentials, and legacy operating systems. Immediate remediation is recommended to prevent full system compromise.

Methodology & Tools

To ensure comprehensive coverage and validate findings, the assessment utilized a multi-tool approach. The primary scanning engines used were:

- **OpenVAS / Greenbone Security Assistant:** Utilized as the primary infrastructure scanner to identify CVEs, misconfigurations, and outdated software.
- **Tenable Nessus:** Employed as a secondary infrastructure scanner to cross-validate findings and identify specific protocol weaknesses (e.g., SMB Badlock).
- **Nikto:** Deployed specifically against web server ports (80) to detect application-layer misconfigurations and missing security headers.

Scan Evidence

OpenVAS / Greenbone

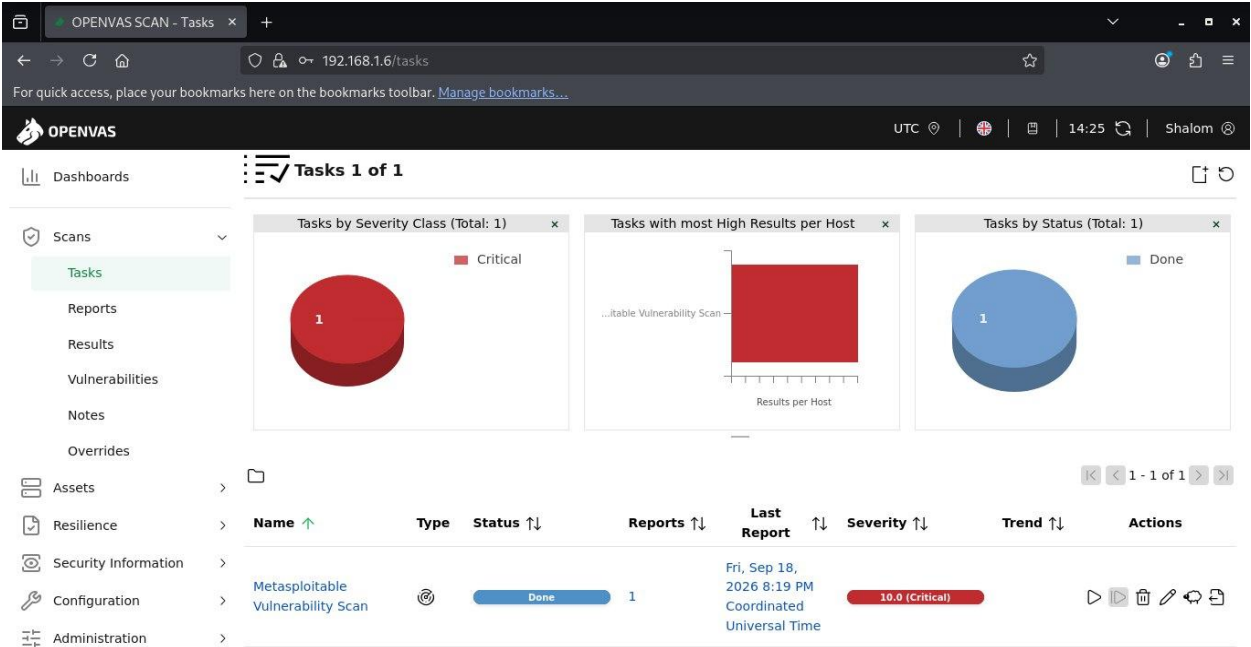


Figure 1: OpenVAS Task Dashboard Overview

This dashboard confirms the successful execution and completion of the "Metasploitable Vulnerability Scan" against the target environment. The task overview indicates a maximum severity score of 10.0 (Critical), which establishes the baseline for the high-risk vulnerabilities analyzed in this assessment

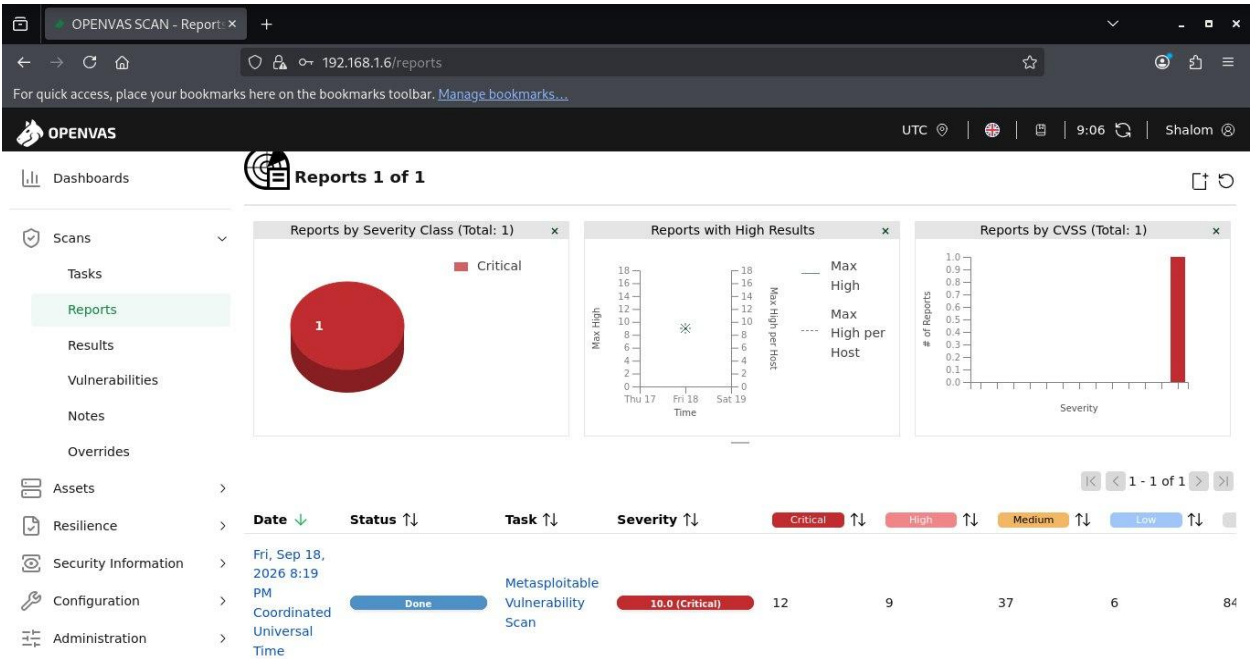


Figure 2: OpenVAS Reports Summary & Severity Distribution

This dashboard provides a quantitative breakdown of the specific vulnerabilities discovered during the completed scan. The report details an alarming volume of severe findings, specifically logging 12 Critical, 9 High, and 37 Medium vulnerabilities across the target scope. This severity distribution visually demonstrates to stakeholders the critically compromised state of the GMDC infrastructure, justifying the need for immediate remediation.

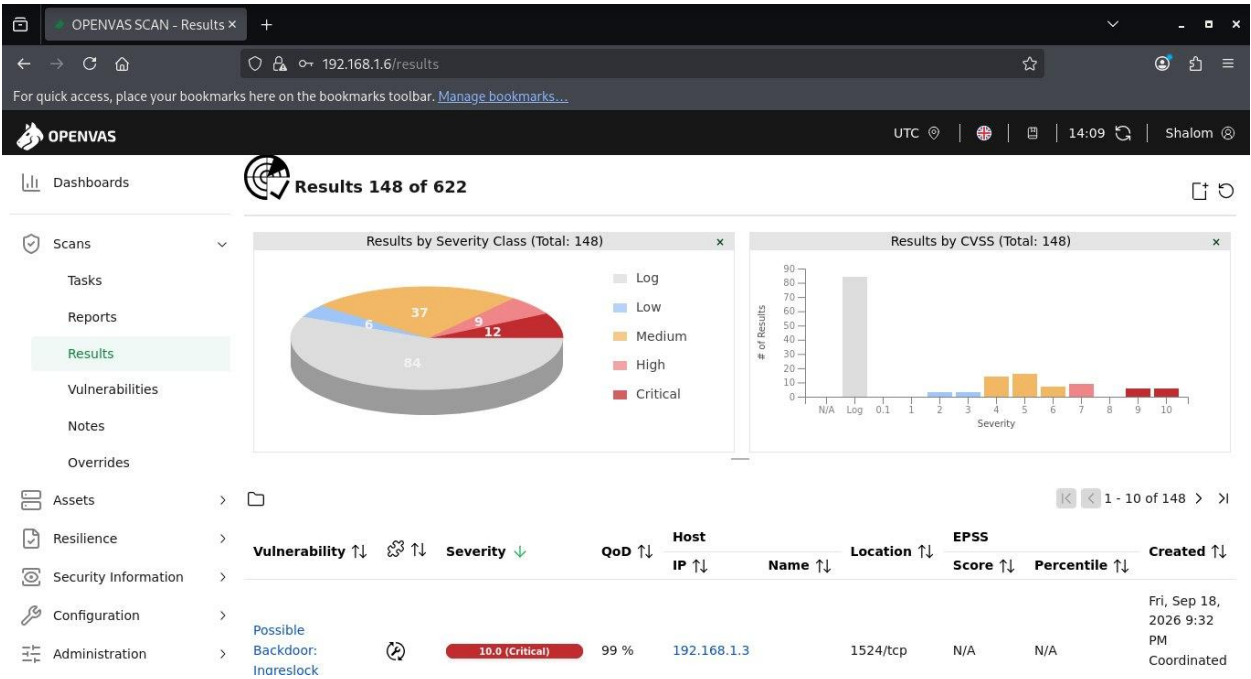


Figure 3: OpenVAS Granular Scan Results & Findings

This view itemizes individual detection entries generated by the engine, displaying specific service flaws ranked by severity. As shown in the findings table, the scanner identified high-confidence, critical risks such as the Ingreslock backdoor running on port 1524/tcp with a 99% Quality of Detection (QoD) rating. This granular output provides the technical verification used to prioritize the critical vulnerability list and target immediate remediation efforts.

OpenVAS Metasploitable Comprehensive Vulnerability Report Overview

This report header captures the macro-level scan execution details and overall vulnerability distribution across target host 192.168.1.3. The aggregate metrics confirm a total of 64 actionable security issues identified with a Quality of Detection (QoD) threshold of 70% or higher, heavily weighted toward Critical (12) and High (9) risk classes. This document forms the primary authoritative baseline for the infrastructure vulnerability findings.



report-b620d022-d934-464c-bf64-41fb1fc5bed9.pdf

Tenable Nessus

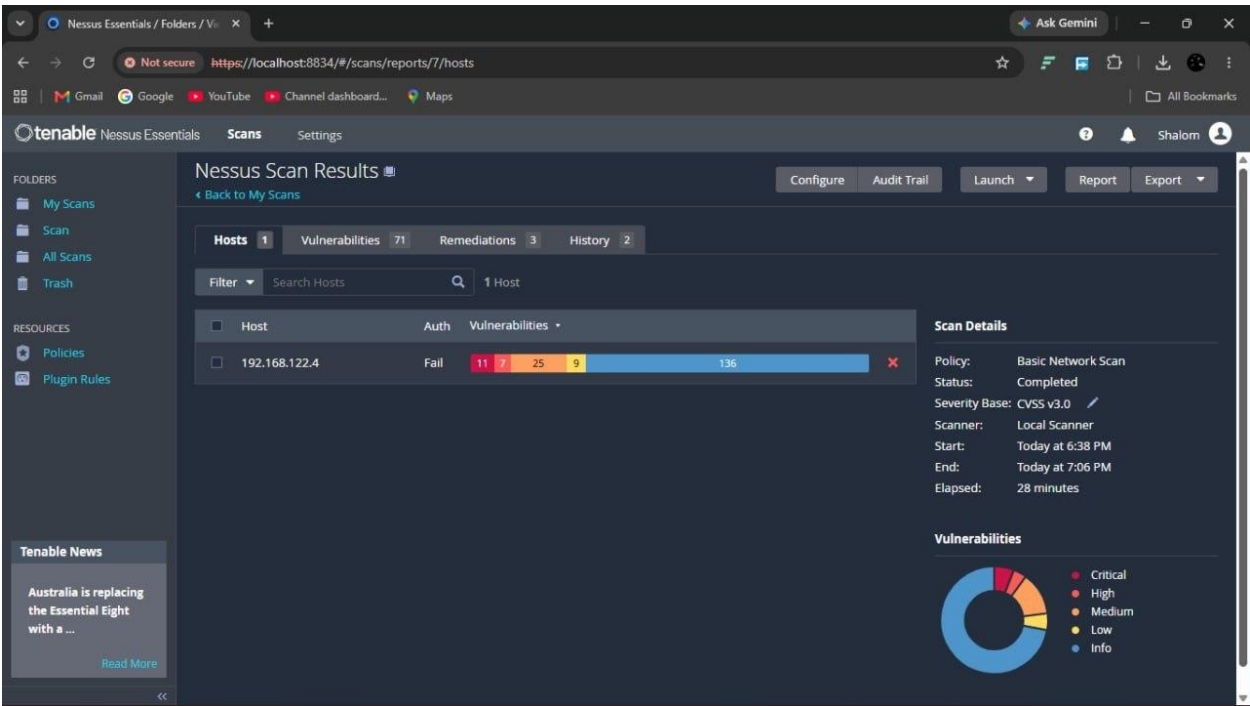


Figure 4: Nessus Metasploitable Target Findings Summary

This dashboard provides a consolidated view of the vulnerabilities detected by Tenable Nessus on target host 192.168.122.4. The scan identified a total of 71 vulnerabilities, confirming 11 Critical, 7 High, and 25 Medium severity risks. This output serves to

validate and corroborate the structural weaknesses, legacy software flaws, and misconfigurations initially detected by the OpenVAS assessment.

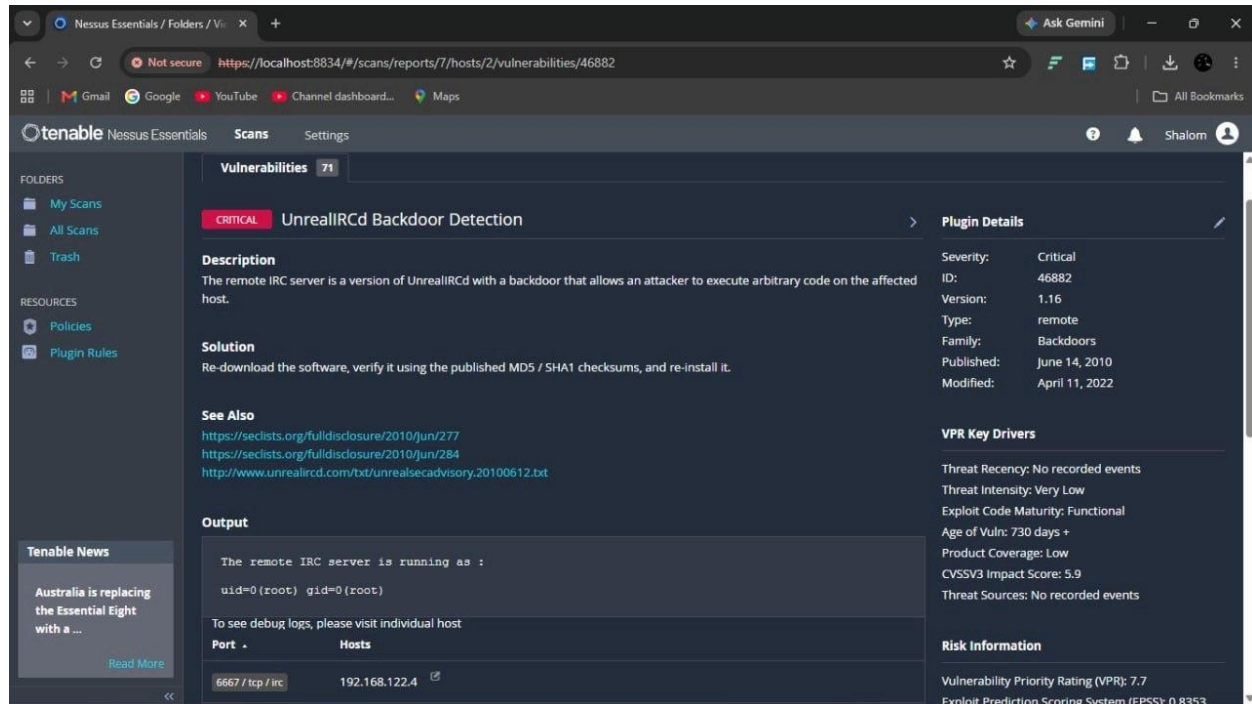
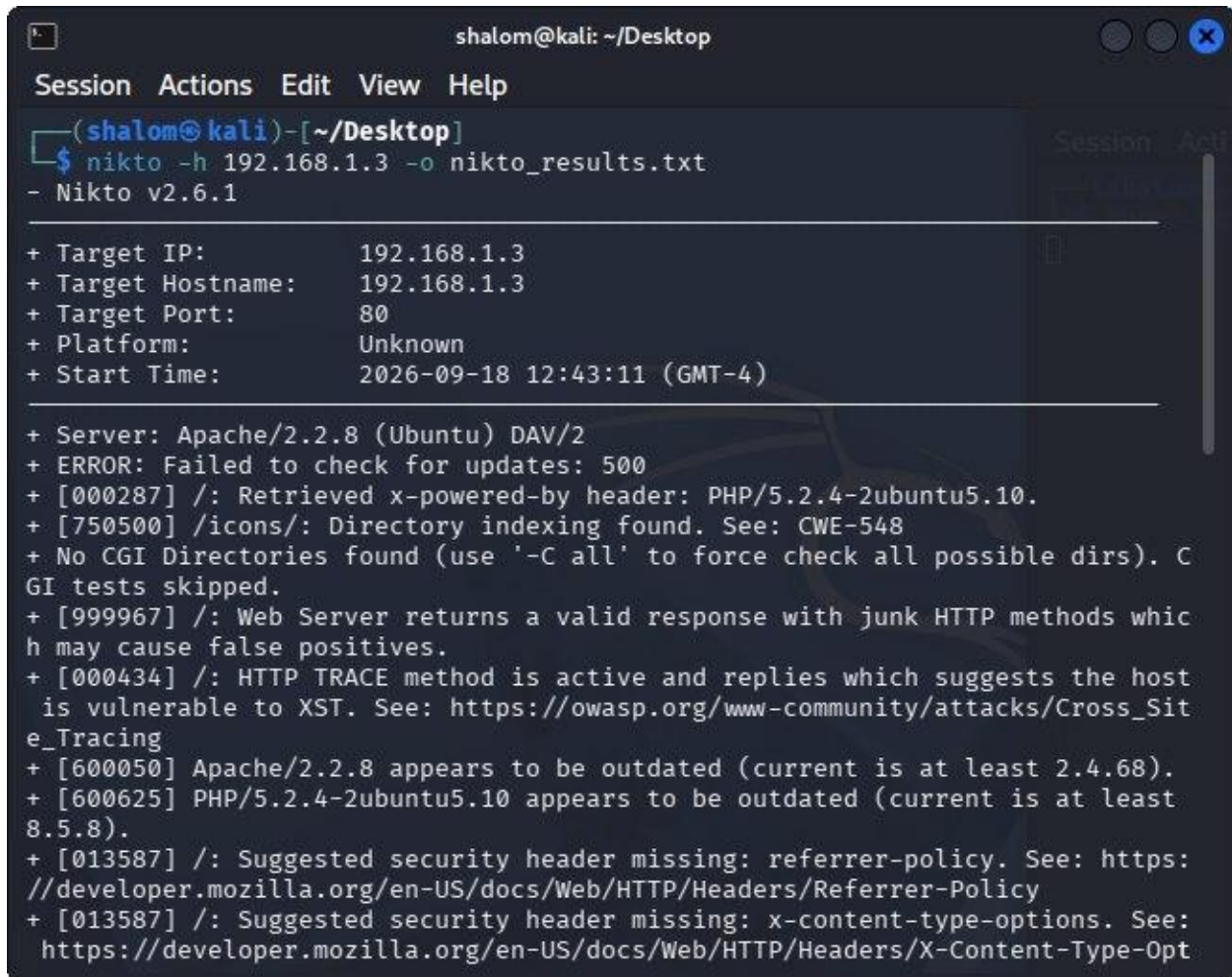


Figure 5: Nessus Plugin #46882 – UnrealIRCd Backdoor Detection (Critical)

This plugin detail view provides technical evidence of a critical vulnerability on the remote IRC server. The service runs a compromised version of UnrealIRCd containing a Trojan backdoor that enables remote unauthenticated attackers to execute arbitrary system commands. Crucially, the scanner output confirms the process is executing under root privileges (`uid=0, gid=0`), meaning any exploitation yields immediate administrative takeover of the underlying host.

Nikto



```
shalom@kali: ~/Desktop
Session Actions Edit View Help
(shalom@kali)-[~/Desktop]
$ nikto -h 192.168.1.3 -o nikto_results.txt
- Nikto v2.6.1

+ Target IP: 192.168.1.3
+ Target Hostname: 192.168.1.3
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-09-18 12:43:11 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates: 500
+ [000287] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found. See: CWE-548
+ No CGI Directories found (use '-C all' to force check all possible dirs). C
GI tests skipped.
+ [999967] /: Web Server returns a valid response with junk HTTP methods whic
h may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host
is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Sit
e_Tracing
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.68).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least
8.5.8).
+ [013587] /: Suggested security header missing: referrer-policy. See: https:
//developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Opt
```

Figure 6: Nikto Web Server Vulnerability Scan Execution

This terminal output shows the automated web assessment conducted against target 192.168.1.3 on HTTP port 80 using Nikto v2.6.1. The scan identified multiple configuration and application-layer security weaknesses, notably including severely outdated server software (Apache 2.2.8 and PHP 5.2.4), active directory indexing on /icons/ (CWE-548), and an enabled HTTP TRACE method rendering the host vulnerable to Cross-Site Tracing (XST). Additionally, the inspection confirmed the absence of essential defensive HTTP response headers, such as X-Content-Type-Options and Referrer-Policy, which exposes end users to client-side attacks and MIME-sniffing exploits.

Nikto Web Assessment Output Report (nikto_results.txt)

This document represents the saved plaintext output generated by the Nikto scanning engine. It acts as the formal export of the web-layer vulnerabilities, detailing specific missing security headers, exposed directory indexing, and outdated server versions discovered on the target's HTTP service. This exported artifact corroborates the live terminal execution and serves as the definitive reference for the application-level misconfigurations affecting the GMDC web portal.



nikto_results.txt

Conclusion & Strategic Recommendations

The vulnerability assessment of the Ghana Maritime Defense Command (GMDC) Metasploitable 2 environment reveals a **Critical** security posture requiring immediate intervention. The presence of pre-installed malicious backdoors (vsftpd, UnrealIRCd), unauthenticated Remote Code Execution flaws (Apache Ghostcat), and factory-default database credentials exposes the infrastructure to imminent compromise. In its current state, an adversary could easily achieve total system takeover, leading to the unauthorized exfiltration, manipulation, or destruction of highly sensitive maritime data and defense tracking systems.

To secure the GMDC infrastructure, the following remediation roadmap is strongly recommended:

Immediate Action:

- **Disable Compromised Services:** Immediately terminate the vsftpd and UnrealIRCd services, as they contain embedded backdoors that cannot be patched. Replace them with secure, modern alternatives (e.g., SFTP via OpenSSH).
- **Enforce Strong Authentication:** Reset all default database credentials (MySQL and PostgreSQL). Implement complex, centrally managed passwords and restrict database access exclusively to authorized internal IP addresses.

- **Disable Cleartext Protocols:** Terminate all legacy Berkeley r-services (rexec, rlogin, rsh) and enforce encrypted SSH protocols for all remote administrative access.

- **Short-Term Remediation:**

- **Patch Web Application Flaws:** Upgrade the Apache Tomcat instance to the latest stable release to eliminate the AJP Ghostcat vulnerability. Disable directory indexing on the Apache web server to prevent structural information disclosure.

- **Long-Term Strategic Action:**

- **Decommission Legacy Operating Systems:** The Ubuntu 8.04 host is structurally indefensible due to its 2013 End of Life status. The server must be entirely decommissioned and its critical services migrated to a modern, actively supported operating system to ensure compliance and baseline security.

Executing this remediation strategy will close the identified attack vectors, neutralize the immediate threat of network pivoting, and restore the operational integrity of the GMDC environment.